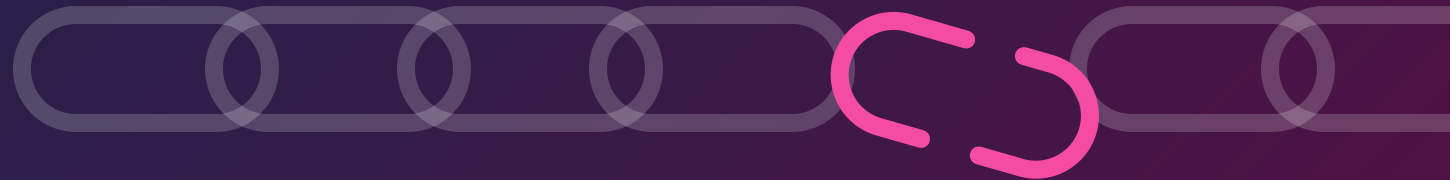


Techniques défensives et offensives des applications Web

Introduction à la cybersécurité

Ce que l'on protège, contre qui, et comment se déroule une attaque. Une intrusion est une chaîne : **il suffit d'en casser un maillon** pour l'arrêter.



Objectifs pédagogiques

À la fin de ce module, vous saurez :

- Expliquer ce qu'on **protège** dans un système d'information, et qualifier l'impact d'une faille.
- Évaluer un **risque** et choisir comment le traiter.
- Décrire le **panorama des menaces** avec des chiffres et des cas réels, en France et dans le monde.
- Distinguer les **profils d'attaquants**, leurs moyens et leurs motivations.
- Nommer les **vecteurs** et les **familles d'attaques**.
- Dérouler une attaque avec la **Cyber Kill Chain** et situer les défenses à chaque étape.

Le fil conducteur

On ne défend bien que ce que l'on comprend. Ce module installe le **vocabulaire commun** (actif, menace, vulnérabilité, risque, vecteur) et le **point de vue de l'adversaire**, réutilisés dans tous les modules suivants.

À retenir

La sécurité n'est pas un produit qu'on installe, mais un **processus** qui traverse tout le cycle de vie d'une application.

■ Ce que fait l'attaquant ■ Ce que fait le défenseur ■ Définitions

Cinq étapes pour penser comme un défenseur

1

Les enjeux d'un système d'information

Critères D-I-C-P, vocabulaire du risque, matrice et traitement, surface d'attaque

2

Le panorama des risques actuels

Chiffres 2025-2026, rançongiciel, hameçonnage, fuites, chaîne d'approvisionnement, cas marquants

3

Les profils des attaquants et leurs objectifs

Du script kiddie à l'APT étatique, motivations, écosystème « as-a-service », menace interne

4

Les vecteurs et les grandes familles d'attaques

Portes d'entrée, logiciels malveillants, ingénierie sociale, attaques Web et réseau

5

Les phases d'une attaque : la Cyber Kill Chain

Les 7 étapes, un cas déroulé de bout en bout, les limites du modèle et MITRE ATT&CK

Trois idées reçues à laisser à la porte

« Nous sommes trop petits pour intéresser qui que ce soit »

Les attaques opportunistes sont automatisées : elles ne choisissent pas, elles ratissent.

Le fait

En France, **48 %** des victimes de rançongiciel recensées en 2025 sont des TPE, PME et ETI.

« Nous avons un antivirus et un pare-feu »

Un outil couvre une étape de l'attaque, pas la chaîne entière — et pas l'humain.

Le fait

L'**élément humain** intervient dans **62 %** des violations de données analysées.

« La sécurité, c'est l'affaire de la DSI »

Une faille naît dans une ligne de code, un choix d'architecture, un contrat fournisseur.

Le fait

Un **tiers** (prestataire, éditeur, dépendance) est impliqué dans **48 %** des violations.

Sources : ANSSI, Panorama de la cybermenace 2025 (mars 2026) · Verizon, Data Breach Investigations Report 2026.

01

Les enjeux d'un système d'information

Avant de parler d'attaques : que cherche-t-on à protéger, et contre quelles pertes ?

Dans cette partie

- Ce qu'est réellement un SI
- Les critères D-I-C et la preuve
- Le vocabulaire du risque
- Évaluer et traiter un risque
- La surface d'attaque
- Les impacts d'un incident

Un SI, c'est bien plus que des serveurs

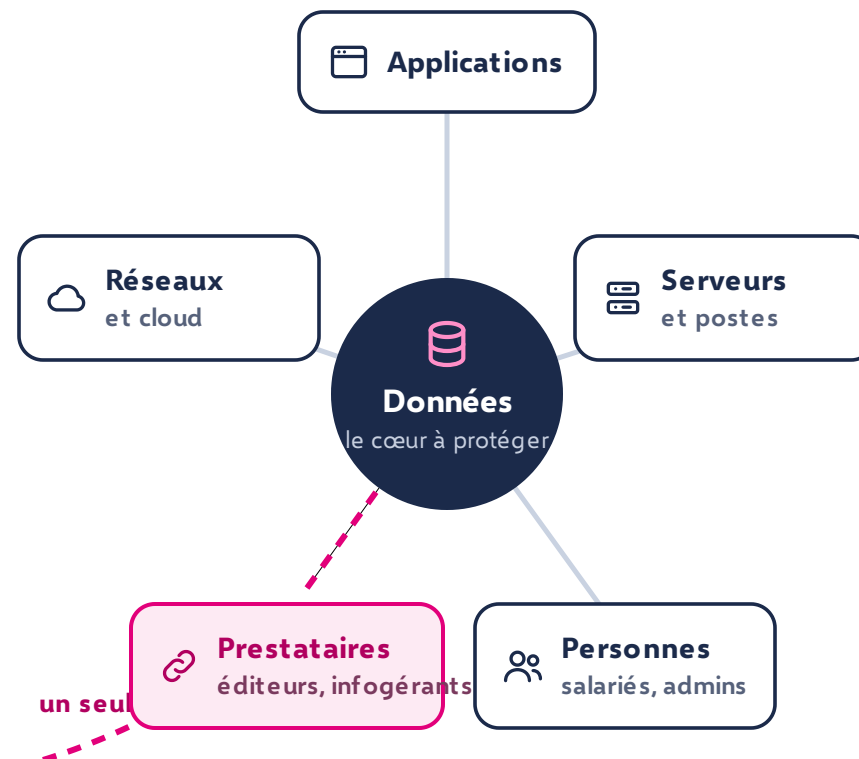
Définition

Le **système d'information (SI)** est l'ensemble organisé des ressources — **matériel, logiciel, données, réseaux, personnes et partenaires** — qui permettent de collecter, stocker, traiter et diffuser l'information d'une organisation.

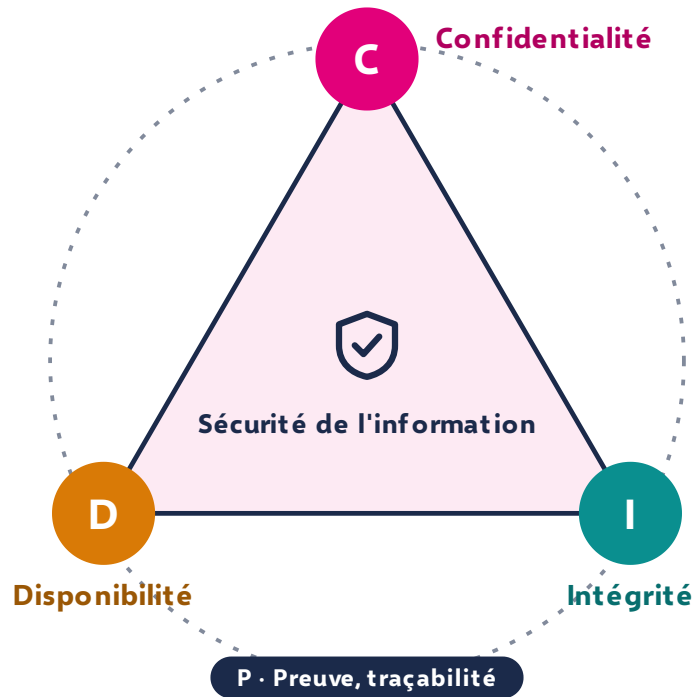
Chaque brique est une **cible potentielle**. L'attaquant ne vise pas la partie la mieux protégée : il cherche le **maillon le plus faible**.

Exemple

Une application e-commerce n'est pas « un site ». C'est le code, la base clients, l'API de paiement, les serveurs, les postes des employés et les prestataires. **Un seul de ces points suffit** à compromettre l'ensemble.



Le triptyque D-I-C, et la preuve



Toute mesure de sécurité vise à préserver trois propriétés de l'information :

- **Confidentialité** — seules les personnes autorisées y accèdent.
- **Intégrité** — elle n'est ni modifiée ni détruite sans autorisation.
- **Disponibilité** — elle est accessible quand on en a besoin.

Le quatrième critère : la preuve

Savoir **qui** a fait **quoi** et **quand** (journalisation, imputabilité, non-répudiation). On parle alors du modèle **DICP**. Nommer le critère touché permet de **qualifier précisément l'impact** d'une faille.

Ce que ça donne sur une application Web

Critère touché	Type d'atteinte	Exemple côté application Web
Confidentialité	Vol ou divulgation de données	Une injection SQL exfiltre la table <code>users</code> (e-mails, mots de passe hachés)
Intégrité	Modification non autorisée	Défiguration d'un site ; montant d'un virement altéré en base
Disponibilité	Interruption de service	Déni de service distribué (DDoS) ; rançongiciel qui chiffre la production
Preuve	Effacement ou absence de traces	Journaux supprimés pour masquer l'intrusion et gêner l'enquête

Exemple combiné — le rançongiciel moderne

Une même attaque casse **plusieurs critères à la fois** : données **indisponibles** (chiffrement), copie volée puis menace de publication (**confidentialité** — la « double extorsion »), sauvegardes détruites (**intégrité**), journaux effacés (**preuve**).

Quel critère est touché ?

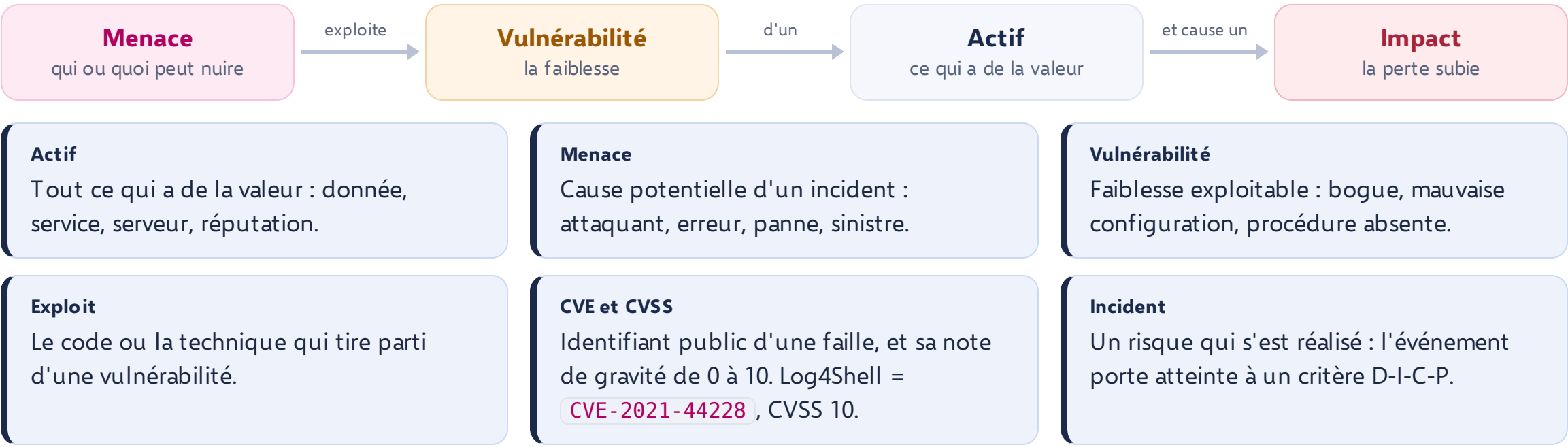
A Un stagiaire consulte les fiches de paie de toute l'entreprise en modifiant un numéro dans l'URL.
Confidentialité — contrôle d'accès défaillant (référence directe non vérifiée).

B Un site marchand devient injoignable le jour des soldes, noyé sous un flot de requêtes.
Disponibilité — déni de service distribué.

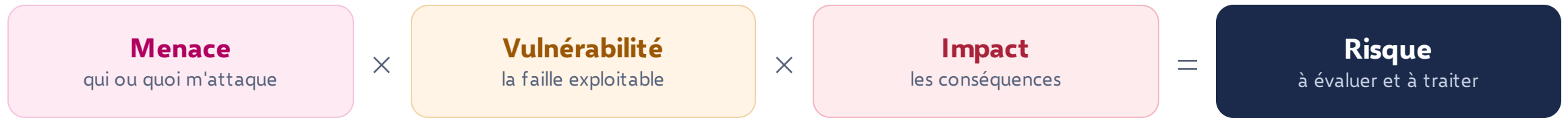
C Un article passe de 499 € à 4,99 € après manipulation d'un paramètre du panier.
Intégrité — donnée métier modifiée côté client sans contrôle serveur.

D Un administrateur nie avoir supprimé une base. Les journaux d'audit étaient désactivés.
Preuve — impossible d'imputer l'action ; l'intégrité est aussi touchée.

Six mots à ne plus confondre



Risque = Menace × Vulnérabilité × Impact



La menace : subie

On ne la supprime pas. On la **connaît** (veille) et on la **surveille** (détection).

La vulnérabilité : on la corrige

Code sécurisé, correctifs, durcissement de la configuration, revue des droits.

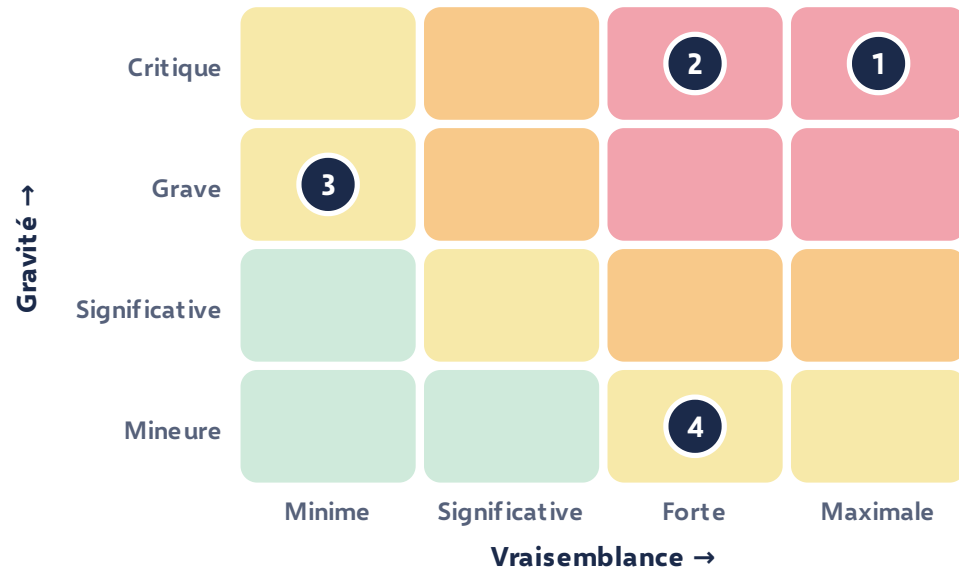
L'impact : on le limite

Sauvegardes, cloisonnement, chiffrement, plan de reprise, réponse à incident.

Nuance

Si un seul facteur vaut zéro, le risque est nul — mais ce cas n'existe pas. L'objectif réaliste est de **ramener le risque à un niveau acceptable** au regard de la valeur de ce qu'on protège.

De la matrice de risque à la décision



- 1 Injection SQL sur une application exposée 2 Rançongiciel
 3 Panne du centre de données 4 Défiguration du site vitrine

Chaque risque est placé selon sa **vraisemblance** et sa **gravité**. Pour chacun, quatre décisions possibles (ISO 27005, EBIOS RM) :

Réduire

Corriger, durcir, détecter, sauvegarder. Le cas le plus fréquent.

Transférer ou partager

Assurance cyber, clause contractuelle, infogérance.

Éviter

Renoncer à la fonctionnalité, ne pas collecter la donnée.

Accepter

Le risque résiduel est assumé, par écrit, par la direction — pas par le développeur.

Tout ce qui est exposé peut être attaqué

Définition

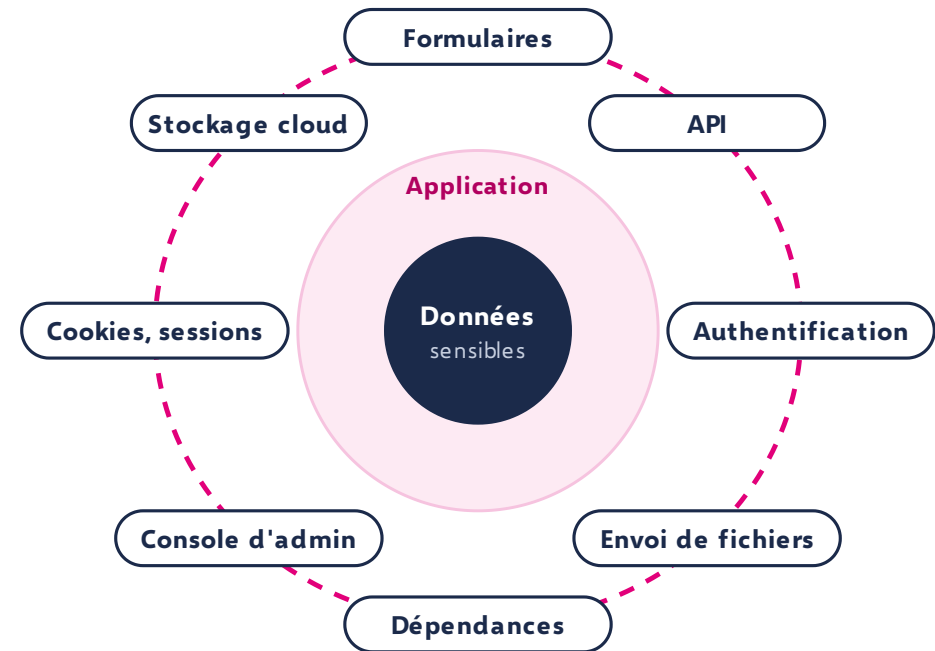
La **surface d'attaque** est l'ensemble des points (entrées, interfaces, services) par lesquels un attaquant peut tenter d'interagir avec le système.

Principe de défense

Réduire cette surface : fermer les ports inutiles, supprimer les services et comptes non nécessaires, restreindre les droits, retirer les dépendances mortes.

Le piège

Chaque fonctionnalité, API ou dépendance ajoutée agrandit la surface — souvent **sans que personne ne tienne l'inventaire**.



Le pointillé : la surface d'attaque

Un incident n'est jamais purement technique



Financier

Perte d'activité, remédiation, rançon, amendes RGPD



Réputation

Confiance des clients et des partenaires, exposition médiatique



Juridique

Notification à la CNIL sous 72 h, responsabilité, contentieux



Opérationnel

Arrêt de production, retour au papier, logistique bloquée



Patrimoine informationnel

Secrets industriels et données personnelles perdus pour de bon



Humain

Épuisement des équipes ; sécurité des personnes à l'hôpital ou dans l'industrie

4,99 M\$

coût moyen mondial d'une violation de données, un **record**

247 jours

pour **identifier** (183) puis **contenir** (64) une violation

Ce que disent ces chiffres

Le temps est le multiplicateur : au-delà de 200 jours, une violation coûte en moyenne **1,3 M\$ de plus**. Détecter tôt est l'investissement le plus rentable.

Source : IBM / Ponemon Institute, Cost of a Data Breach Report 2026.

02

Le panorama des risques actuels

Qui attaque aujourd'hui, avec quels moyens, à quelle échelle — chiffres et cas à l'appui.

Dans cette partie

- Les tendances mondiales 2026
- La situation en France
- Les grandes catégories de menaces
- Rançongiciel et hameçonnage
- Fuites et chaîne d'approvisionnement
- Dix incidents qui ont fait école

Une menace industrialisée et permanente

48 %

des violations impliquent un **rançongiciel** (44 % un an plus tôt)

31 %

débutent par l'**exploitation d'une vulnérabilité** : premier vecteur d'accès, devant les identifiants volés

43 jours

délai médian pour **corriger** une faille critique — l'exploitation, elle, démarre en quelques jours

1 sur 4

attaques malveillantes s'appuie désormais sur l'**IA** (hameçonnage, reconnaissance, code)

Ce qui accélère la menace

- **Cybercrime-as-a-service** : des outils clés en main à louer
- **Automatisation et IA** : hameçonnage crédible à grande échelle
- **Infostealers** : des identifiants volés en masse, revendus, puis réutilisés

Ce qui nous expose

- **Surface qui explose** : cloud, API, télétravail, accès distants (VPN)
- **Composants non corrigés** et dépendances tierces
- **Erreurs de configuration** : stockage public, droits trop larges

Sources : Verizon DBIR 2026 (22 000 violations confirmées, 145 pays) · IBM Cost of a Data Breach Report 2026.

Ce que voit l'ANSSI : un plateau haut

3 586

événements de sécurité
traités en 2025

1 366

incidents confirmés (1 361 en
2024) : stable

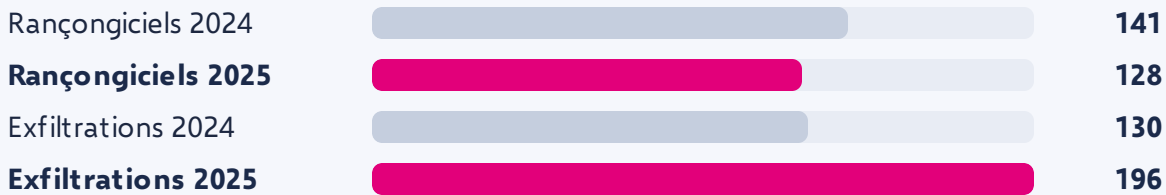
Lecture

La baisse des événements (−18 %) tient à l'effet des Jeux de Paris en 2024. Les incidents réels, eux, ne reculent pas, et la menace **se déplace du chiffrement vers le vol de données**.

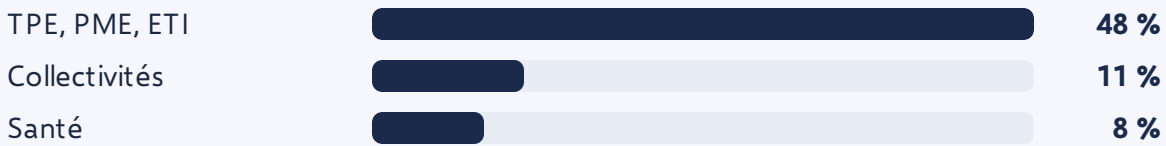
Brouillage

Des groupes liés à des États louent des rançongiciels criminels ; les criminels adoptent des techniques d'espionnage. Attribuer une attaque devient plus difficile.

Rançongiciels et exfiltrations, 2024 → 2025



Victimes de rançongiciel en 2025



Souches les plus actives : Qilin (21 %), Akira (9 %), LockBit 3.0 (5 %).

Source : ANSSI / CERT-FR, Panorama de la cybermenace 2025, publié le 11 mars 2026.

Les grandes catégories de menaces

Catégorie	But de l'attaquant	Illustration concrète	Critère
Rançongiciel	Extorsion financière	Chiffrer et voler les données, puis exiger une rançon	D • C
Hameçonnage, ingénierie sociale	Voler des accès	Faux e-mail, fausse page de connexion, appel d'un « support »	C
Attaques Web applicatives	Compromettre l'application	Contrôle d'accès défaillant, injection, XSS (OWASP Top 10)	C • I
Fuite ou vol de données	Revendre, espionner	Base clients exposée, secrets exfiltrés, identifiants en vente	C
Déni de service (DDoS)	Nuire, faire pression	Site saturé de requêtes et rendu injoignable	D
Chaîne d'approvisionnement	Toucher mille cibles d'un coup	Dépendance, prestataire ou mise à jour d'éditeur piégés	I • C

Comment se déroule une attaque par rançongiciel



Entre l'étape 1 et l'étape 4 : de quelques heures à plusieurs semaines. C'est la fenêtre de détection.

Double, voire triple extorsion

L'attaquant chiffre, **menace de publier** les données volées, puis fait pression sur les clients ou lance un DDoS. Certains groupes ne chiffrent même plus : le vol suffit.

La vraie parade

Sauvegardes hors-ligne testées, segmentation du réseau, **MFA** sur tous les accès distants et **détection précoce**. Payer ne garantit ni la clé, ni le silence : **69 %** des victimes ne paient pas.

Anatomie d'un e-mail d'hameçonnage



- 1 **Domaine imité** : « nova1ia » avec le chiffre 1, suffixe rassurant ajouté.
- 2 **Urgence et menace** pour court-circuiter la réflexion.
- 3 **Formule générique** : l'expéditeur ne connaît pas votre nom.
- 4 **URL réelle** différente du texte affiché, en HTTP.
- 5 **Pièce jointe à macros** (.docm) non sollicitée.

Parades

Technique : MFA résistant à l'hameçonnage (clés FIDO2), filtrage, SPF, DKIM, DMARC. **Humaine** : entraînement régulier, et un bouton « signaler » sans reproche.

Fuite de données et chaîne d'approvisionnement



Fuite de données

Des données sensibles sont exposées par une faille, une **mauvaise configuration** (stockage cloud public, sauvegarde accessible) ou un vol d'identifiants.

Exemple

Une base accessible sans mot de passe est indexée par un moteur spécialisé (Shodan) et copiée en quelques minutes.

Parade

Inventaire des expositions, chiffrement, moindre privilège, revue de configuration.



Chaîne d'approvisionnement logicielle

On n'attaque plus la cible, mais un **fournisseur** ou une **dépendance** qu'elle utilise — pour toucher tous ses clients d'un coup.

Exemple

Un paquet npm ou PyPI compromis, un pipeline CI/CD détourné, une mise à jour d'éditeur signée mais piégée.

Parade

Inventaire des composants (SBOM), versions épinglées, vérification d'intégrité, veille CVE.

OWASP Top 10:2025

Ces deux sujets entrent dans le trio de tête : **A02 Security Misconfiguration** (5e en 2021) et **A03 Software Supply Chain Failures** (catégorie élargie), juste derrière **A01 Broken Access Control**. Nous y revenons dans les modules dédiés.

Six cas qui ont fait école



Le point commun

Presque tous reposent sur une **vulnérabilité connue et corrigable**, une **dépendance mal maîtrisée** ou une **erreur humaine** — rarement sur une attaque inédite et « magique ».

Et en France : quatre cas récents

Août 2022

Hôpital de Corbeil-Essonnes

Rançongiciel LockBit. Retour au papier, patients transférés, données publiées après refus de payer.

Février 2024

Viamedis et Almerys

Tiers payant : données de **33 millions** d'assurés, via des comptes de professionnels de santé hameçonnés.

Mars 2024

France Travail

43 millions de personnes potentiellement concernées, via des comptes de conseillers partenaires usurpés.

Octobre 2024

Free

Accès à un outil de gestion interne : **19 millions** d'abonnés, dont 5 millions d'IBAN.

Le schéma qui se répète

Pas d'exploit sophistiqué : un **compte légitime** — souvent celui d'un partenaire — est volé, puis utilisé pour extraire les données en masse.

Ce qui aurait changé l'issue

MFA pour les comptes tiers, **moindre privilège**, plafonds de volume et **alerte** sur les extractions anormales.

03

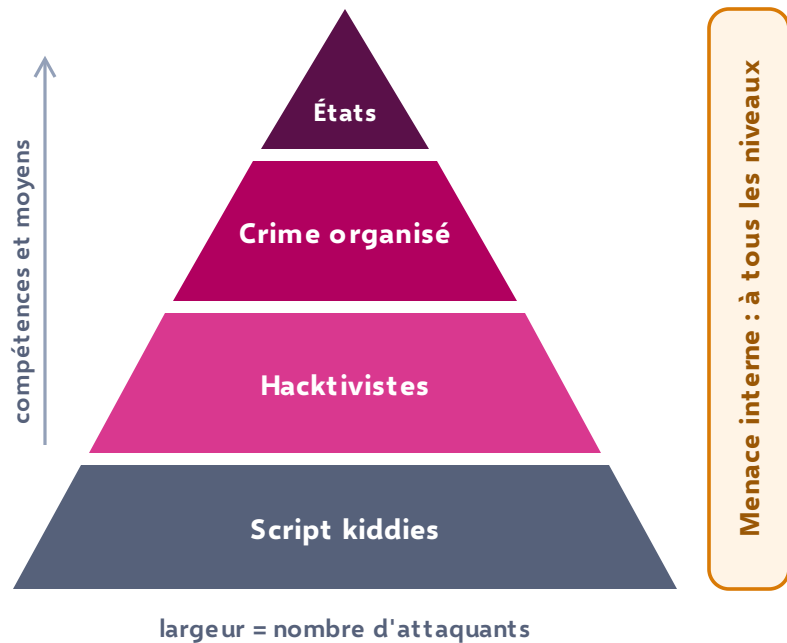
Les profils des attaquants et leurs objectifs

Connaître son adversaire pour calibrer une défense proportionnée.

Dans cette partie

- La pyramide des attaquants
- Compétences, moyens, cibles
- Six motivations
- L'économie du « as-a-service »
- La menace interne

Du curieux à l'attaquant étatique



- **Script kiddies** — peu compétents, réutilisent des outils tout faits ; très nombreux, opportunistes.
- **Hacktivistes** — portés par une cause ; défiguration, DDoS, fuites pour faire du bruit.
- **Crime organisé** — professionnels du profit ; rançongiciel, fraude, revente de données.
- **États** et groupes **APT** (*Advanced Persistent Threat*) — très financés, patients, discrets ; espionnage et sabotage.

Hors pyramide

La **menace interne** — salarié, prestataire, ancien collaborateur — ne se classe pas par compétence : elle dispose **déjà d'un accès légitime**.

Compétences, moyens, cibles : la fiche comparée

Profil	Compétence	Moyens	Patience	Cibles et méthodes typiques	Exemples connus
Script kiddie	● ● ● ●	● ● ● ●	Minutes	Tout ce qui est exposé et non corrigé ; outils automatiques	Anonymes, outils publics
Hacktiviste	● ● ● ●	● ● ● ●	Jours	Institutions, entreprises symboliques ; DDoS, défiguration	NoName057(16), Anonymous
Crime organisé	● ● ● ●	● ● ● ●	Semaines	Toute organisation solvable ; rançongiciel, fraude, vol de données	Qilin, Akira, LockBit, Cl0p
État, APT	● ● ● ●	● ● ● ●	Mois, années	Défense, énergie, télécoms, recherche ; zero-day, supply chain	APT28, APT41, Lazarus
Interne	Variable	Accès légitime	Variable	Son propre employeur ; vol, sabotage, ou simple négligence	Salarié, prestataire, ex-admin

À retenir

Face au bas du tableau, l'**hygiène** suffit (correctifs, MFA, sauvegardes). Face au haut, il faut en plus de la **détection** et de la **réponse** : l'intrusion finira par réussir.

Pourquoi attaquent-ils ?



Appât du gain

Rançon, fraude, revente de données : la motivation très largement dominante



Espionnage

Secrets industriels, données stratégiques, renseignement : environ 12 % des violations



Idéologie

Cause politique, sociale ou environnementale (hacktivism)



Sabotage

Déstabiliser, détruire ; souvent d'origine étatique (énergie, télécoms)



Défi, notoriété

Prouver sa compétence, se faire un nom dans une communauté



Vengeance

Salarié mécontent, ancien prestataire dont les accès n'ont pas été fermés

Pourquoi c'est utile

La **motivation** détermine la **cible** et la **persévérance**. Un profil financier cherche le gain rapide et passe à la victime suivante si c'est trop dur ; un État investit des mois pour atteindre un objectif précis.

Source du chiffre : Verizon DBIR 2026 (acteurs externes).

La cybercriminalité s'est industrialisée

Le crime organisé fonctionne comme une **économie de services** : chacun se spécialise et **loue** son savoir-faire aux autres.

Ransomware-as-a-Service

Kits d'hameçonnage

Courtiers d'accès (IAB)

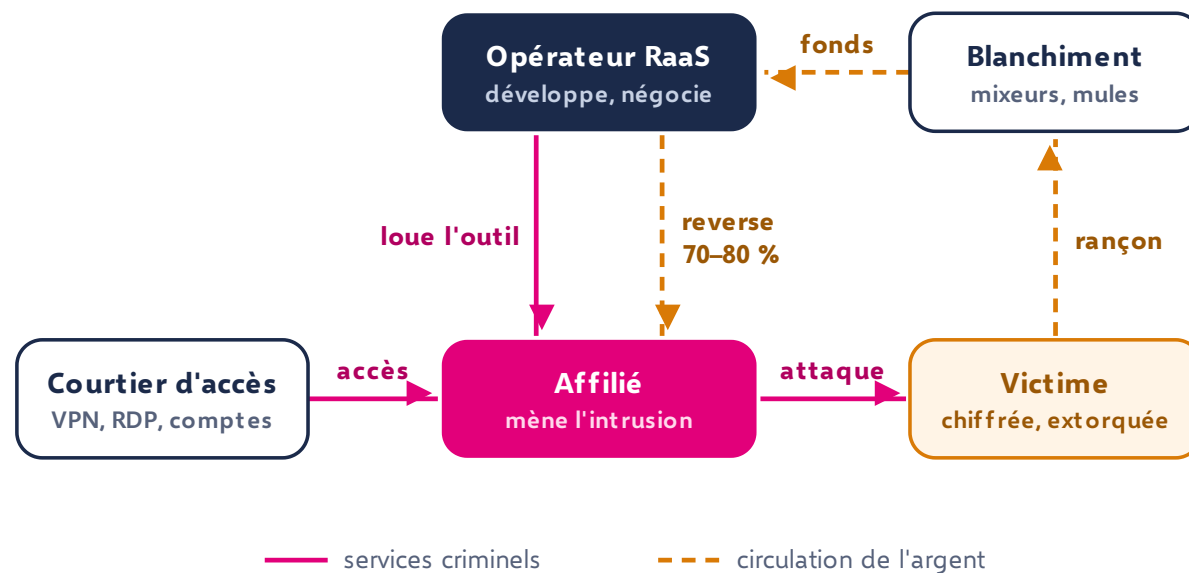
Journaux d'infostealers

Hébergement « bulletproof »

Blanchiment crypto

Conséquence directe

Plus besoin d'être expert : un **affilié** achète un accès, loue un rançongiciel et garde 70 à 80 % de la rançon. La barrière d'entrée s'effondre, le **volume d'attaques explose**.



Adapter la protection à la menace réaliste

Toutes les organisations n'affrontent pas les mêmes adversaires. Estimer **qui** a intérêt à m'attaquer et **avec quels moyens** est le point de départ de l'analyse de risque.

Organisation	Adversaire le plus probable
PME e-commerce	Crime opportuniste, rançongiciel, fraude au paiement
Laboratoire de R&D	Espionnage ciblé et patient
Collectivité, administration	Rançongiciel, hacktivisme, acteurs étatiques
Hôpital	Rançongiciel : la pression vitale pousse à payer

Ne jamais oublier la menace interne

Un collaborateur — malveillant ou simplement négligent — dispose **déjà d'un accès légitime**. Aucune étape d'intrusion à détecter : c'est l'un des risques les plus difficiles à voir.

D'où les principes à venir

Moindre privilège, séparation des rôles, journalisation, revue régulière des accès et fermeture des comptes au départ.

Question à la salle

Pour votre application, qui sont les deux adversaires les plus plausibles ? Que cherchent-ils ?

04

Les vecteurs et les grandes familles d'attaques

Par où l'attaquant entre, et de quelles armes il dispose une fois à l'intérieur.

Dans cette partie

- Surface, vecteur, charge utile
- Six portes d'entrée
- Six familles d'attaques
- Savoir nommer un malware
- L'ingénierie sociale
- L'enchaînement des briques

Vecteur d'attaque : le chemin d'entrée

Définition

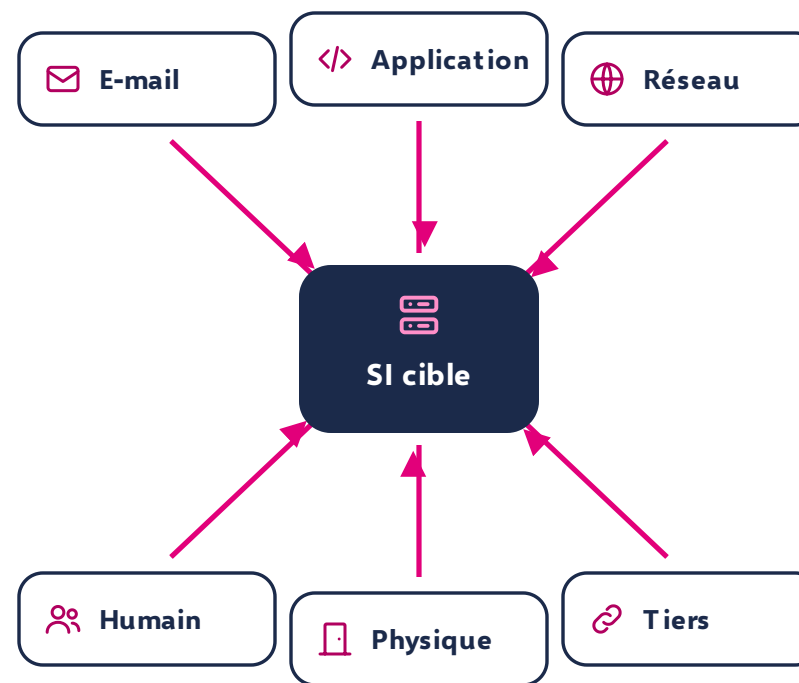
Un **vecteur d'attaque** est le moyen ou le chemin par lequel un attaquant accède au système ou y introduit une charge malveillante.

Quatre notions à ne pas confondre :

- **Surface d'attaque** — l'ensemble des points exposés (le « où »).
- **Vecteur** — le chemin emprunté pour entrer (le « par où »).
- **Exploit** — la technique qui déclenche la faille (le « comment »).
- **Charge utile** (*payload*) — ce qui s'exécute une fois entré (le « quoi »).

Exemple

Vecteur : un e-mail piégé. Exploit : la macro qui s'exécute à l'ouverture.
Charge utile : l'implant qui ouvre un accès distant.



Six portes d'entrée à surveiller

Vecteur	Comment il est exploité	Contre-mesure clé
Application Web, API	Contrôle d'accès contourné, injection, XSS, faille d'un composant	Code sécurisé, correctifs, WAF
Services exposés	VPN ou équipement de bordure vulnérable, RDP ouvert, port oublié	Réduction de surface, correctifs rapides
Identifiants	Mot de passe faible ou réutilisé, <i>credential stuffing</i> , infostealer	MFA, gestionnaire de mots de passe
E-mail, messagerie	Hameçonnage, pièce jointe piégée, lien malveillant	Filtrage, DMARC, entraînement
Humain	Faux support, pression hiérarchique, corruption	Procédures de vérification
Tiers, supply chain	Dépendance, prestataire ou mise à jour compromis	SBOM, contrôle d'intégrité, MFA des tiers

Ordre de grandeur 2026

Accès initial observé : exploitation de vulnérabilités **31 %**, abus d'identifiants **13 %**. Mais sur l'ensemble de la chaîne d'attaque, les identifiants volés restent présents dans **39 %** des cas (Verizon DBIR 2026).

Les grandes familles d'attaques



Logiciels malveillants

Virus, ver, cheval de Troie, rançongiciel, infostealer, rootkit, botnet



Attaques Web

Contrôle d'accès défaillant, injection SQL, XSS, CSRF, SSRF — le cœur de cette formation



Ingénierie sociale

Hameçonnage, faux prétexte, arnaque au président, appâtage, deepfake



Attaques sur les accès

Force brute, *credential stuffing*, vol de session, fatigue MFA, pass-the-hash



Attaques réseau

Interception (*man-in-the-middle*), usurpation, empoisonnement DNS, écoute



Déni de service

DDoS volumétrique, ou applicatif : requêtes lentes ou coûteuses (Slowloris)

Lecture

Ces familles ne s'excluent pas : elles se **combinent**. Un hameçonnage livre un malware, qui vole une session, qui ouvre l'application.

Savoir nommer un malware

Type	Caractéristique distinctive	Se reconnaît à...
Virus	Se greffe à un fichier légitime et s'exécute avec lui	Besoin d'un hôte et d'une action humaine
Ver (<i>worm</i>)	Se propage seul de machine en machine par le réseau	Propagation fulgurante (WannaCry)
Cheval de Troie	Se fait passer pour un logiciel utile afin d'être installé volontairement	Faux installateur, logiciel piraté
Rançongiciel	Chiffre les données et exige une rançon pour la clé	Fichiers renommés, note de rançon
Infostealer, spyware	Vole mots de passe, cookies de session et frappes clavier	Comptes compromis sans alerte
Rootkit	Se dissimule au plus profond du système pour garder un accès furtif	Invisible des outils du système
Botnet	Réseau de machines « zombies » pilotées à distance	DDoS, spam, minage, proxy

Ces catégories décrivent un **comportement**, pas une espèce : un même code peut être ver, cheval de Troie et rançongiciel à la fois.

Le maillon humain, cible privilégiée

Définition

L'**ingénierie sociale** contourne la technique en manipulant la **confiance**, l'**autorité**, l'**urgence** ou la **curiosité** des personnes.

- **Faux prétexte** (*pretexting*) — un scénario crédible : faux support, faux fournisseur, fil de discussion détourné.
- **Appâtage** (*baiting*) — clé USB « oubliée », téléchargement gratuit piégé.
- **Talonnage** (*tailgating*) — entrer en suivant une personne autorisée.
- **Deepfake** — voix ou visage d'un dirigeant imités par IA pour ordonner un virement.

Leviers psychologiques exploités

Autorité

Urgence

Peur

Confiance

Curiosité

Envie d'aider

Parades

Une **procédure de contre-appel** pour toute demande sensible (virement, réinitialisation de MFA), le **droit de dire non** à un supérieur pressé, et une culture où signaler une erreur n'est pas puni.

Tendance

Le faux prétexte s'insère de plus en plus dans des échanges existants : le signal n'est plus le lien suspect, mais le **comportement inhabituel**.

Une attaque réelle combine plusieurs briques



Une intrusion est une **chaîne d'étapes**. Chacune rapproche l'attaquant de son but, mais **casser un seul maillon** suffit souvent à tout arrêter. C'est l'idée de la **Cyber Kill Chain**, que nous détaillons maintenant.

05

Les phases d'une attaque : la Cyber Kill Chain

Décomposer une intrusion en étapes pour savoir où et comment l'interrompre.

Dans cette partie

- Pourquoi modéliser l'attaque
- Les 7 étapes, une à une
- Une défense pour chaque étape
- Un cas déroulé de bout en bout
- Les limites du modèle
- Le relais : MITRE ATT&CK

Pourquoi modéliser l'attaque en étapes ?

Définition

La **Cyber Kill Chain** (Lockheed Martin, 2011) décrit une intrusion comme une **séquence de 7 étapes** que l'attaquant doit toutes franchir pour atteindre son objectif.

- L'attaquant doit réussir **toutes** les étapes.
- Le défenseur n'a qu'à en **bloquer une seule**.
- Chaque étape laisse des **traces** : autant d'occasions de détecter.

Le terme vient du vocabulaire militaire : la « chaîne » d'actions qui mène de l'identification d'une cible à sa neutralisation.

Idée-force

Plus on détecte **tôt**, moins l'attaque coûte à contenir. Repérer l'attaquant à la livraison est incomparablement préférable à le découvrir à l'exfiltration.

Un langage commun

La Kill Chain sert de repère partagé entre l'équipe offensive (**red team**), l'équipe défensive (**blue team**) et la direction pour situer un incident.

Les 7 étapes de la Cyber Kill Chain



Sens de lecture

De gauche, où l'attaquant prépare à distance, à droite, où il agit sur sa cible. Les couleurs vont du **froid** (préparation) au **chaud** (impact). Un repère en haut à droite des diapositives suivantes indique l'étape en cours.

Côté défense

Les étapes 1 et 2 se passent **hors de notre vue**. De 3 à 7, chaque étape se joue chez nous : nous pouvons **détecter, bloquer, ralentir**.

Reconnaissance et armement

1 Reconnaissance

Collecter un maximum d'informations : organigramme, technologies, noms de domaine, services exposés, adresses e-mail, identifiants déjà fuités.

Ce que fait l'attaquant

Il liste le personnel sur les réseaux professionnels, interroge Shodan et les certificats TLS, lit les offres d'emploi pour deviner la **pile technique**.

Défense

Réduire l'exposition publique, surveiller les scans et les fuites d'identifiants de l'entreprise.

2 Armement (weaponization)

Coupler un **exploit** à une **charge utile** pour fabriquer un objet livrable : document piégé, exécutable, requête forgée.

Ce que fait l'attaquant

Un classeur à macro malveillante ; ou une requête HTTP sur mesure contre la version exacte du CMS repérée à l'étape 1.

Défense

Étape hors de notre réseau : s'y préparer par la **veille** et le renseignement sur les menaces (CTI).

Livraison et exploitation

3 Livraison (delivery)

Acheminer l'arme jusqu'à la cible : e-mail, lien, clé USB, site piégé — ou directement une requête vers une application exposée.

Ce que fait l'attaquant

Un e-mail soigné avec pièce jointe et prétexte crédible ; ou un simple **POST** vers un formulaire vulnérable.

Défense

Filtrage e-mail et Web, WAF, bac à sable, macros désactivées par défaut, entraînement.

4 Exploitation

La vulnérabilité est déclenchée : le code malveillant **s'exécute** sur le système de la cible et y prend pied.

Ce que fait l'attaquant

La victime ouvre la pièce jointe et la macro se lance ; ou une injection provoque une exécution de code côté serveur.

Défense

Correctifs à jour, validation des entrées, durcissement, EDR, moindre privilège.

Installation et commande-contrôle

5 Installation

Installer une **porte dérobée** pour **persister** : garder l'accès après un redémarrage ou un changement de mot de passe.

Ce que fait l'attaquant

Tâche planifiée, service malveillant, compte administrateur caché ; sur un serveur Web, un **webshell** déposé dans un dossier d'upload.

Défense

Contrôle d'intégrité des fichiers, EDR, revue des comptes et des tâches planifiées.

6 Commande et contrôle (C2)

L'implant **contacte le serveur de l'attaquant** pour recevoir des ordres : la machine est pilotée à distance.

Ce que fait l'attaquant

Des communications régulières et discrètes, camouflées dans du trafic HTTPS ou DNS, parfois via un service cloud légitime.

Défense

Filtrage du trafic **sortant**, proxy, détection des balises régulières et des domaines récents.

Actions sur objectif

L'attaquant atteint son **but**, qui dépend de sa motivation initiale :



Exfiltrer

Vol, espionnage, revente



Chiffrer

Extorsion par rançongiciel



Détruire

Sabotage, effacement



Rebondir

Vers les clients et partenaires

Défense

Prévention des fuites (DLP), segmentation, sauvegardes hors-ligne, journaux exploitables, plan de réponse à incident **répété**.

Trop tard pour l'impact, pas pour les leçons

Chaque incident doit nourrir un **retour d'expérience sans blâme** qui renforce les étapes amont.

Rappel

Si l'attaquant est arrivé ici, c'est qu'**aucune** des six étapes précédentes n'a été bloquée. D'où la **défense en profondeur** : plusieurs barrières indépendantes.

À chaque phase, une occasion de rompre la chaîne

Étape	Détecter	Bloquer ou limiter
1 Reconnaissance	Journaux Web, alertes de scan, veille sur les fuites	Exposition publique réduite, bannières masquées
2 Armement	Renseignement sur les menaces, indicateurs partagés (IOC)	— hors de portée
3 Livraison	Passerelle e-mail, WAF, signalements des utilisateurs	Filtrage, bac à sable, macros bloquées
4 Exploitation	EDR, erreurs applicatives anormales	Correctifs, validation des entrées, moindre privilège
5 Installation	Contrôle d'intégrité, nouveaux comptes ou tâches	Listes d'applications autorisées, dossiers d'upload non exécutables
6 Commande et contrôle	Anomalies DNS et proxy, balises régulières	Filtrage sortant par défaut
7 Actions sur objectif	Volumes sortants, accès massifs aux données	Segmentation, sauvegardes hors-ligne, réponse à incident

Douze jours dans le SI d'un hôpital

Étape	Quand	Ce que fait l'attaquant	Ce qui aurait rompu la chaîne
1 Reconnaissance	J – 30	Repère les agents de la facturation sur un réseau professionnel	Moins d'informations publiques
2 Armement	J – 10	Prépare un classeur à macro qui télécharge un implant	— (veille sur la menace)
3 Livraison	J, 09 h 12	Envoie « facture impayée » à trois agents	Filtrage des pièces jointes à macros
4 Exploitation	J, 09 h 40	Un agent active la macro : code exécuté sur son poste	Macros bloquées, EDR, poste sans droits admin
5 Installation	J, 09 h 41	Crée une tâche planifiée pour survivre au redémarrage	Alerte sur nouvelle tâche planifiée
6 C2	J → J + 12	Balise HTTPS toutes les 5 minutes ; vole un compte administrateur du domaine	Filtrage sortant, comptes admin cloisonnés
7 Objectif	J + 12, nuit	À 2 h du matin : exfiltre 40 Go, détruit les sauvegardes en ligne, chiffre les serveurs	Segmentation, sauvegardes hors-ligne

Scénario fictif, composé d'éléments observés dans des incidents réels. Sept occasions d'arrêter l'attaque ; une seule suffisait.

Ce que la Kill Chain décrit mal

Un modèle centré sur le malware et le périmètre

Conçu en 2011 pour des intrusions par logiciel malveillant venues de l'extérieur. Trois situations lui échappent en partie :

- **Menace interne** — l'accès existe déjà : les étapes 1 à 5 disparaissent.
- **Attaque Web directe** — une injection SQL fusionne les étapes 3, 4 et 7 en une requête, sans rien installer.
- **Cloud et identités volées** — se connecter avec un compte valide ne ressemble à aucune « exploitation ».

Ce qui se passe après l'entrée

Le modèle résume en deux cases (6 et 7) ce qui occupe l'attaquant pendant des semaines : élévation de privilèges, découverte, latéralisation, collecte.

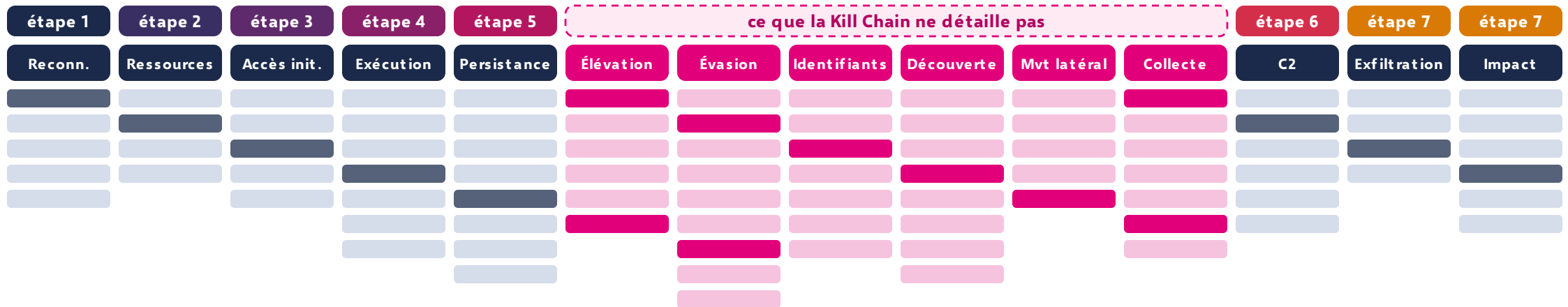
Les modèles qui prennent le relais

Unified Kill Chain (18 phases, de l'entrée à l'objectif en passant par la propagation) et **MITRE ATT&CK**, la référence opérationnelle.

Conclusion

La Kill Chain reste le meilleur **récit** pour expliquer une attaque. Pour **outiller** la défense, il faut plus fin.

De la Kill Chain à MITRE ATT&CK



Chaque barre : une technique. En foncé : techniques observées dans un incident donné.

Cyber Kill Chain

Linéaire, 7 étapes. Vue stratégique, simple à expliquer : le **récit** de l'attaque.

MITRE ATT&CK

Matrice de 14 tactiques et de centaines de techniques, fondée sur des **attaques observées**.

Usage côté défense

Cartographier ses détections technique par technique, et **voir les trous**. On y revient avec STRIDE au module suivant.

Cinq questions pour fixer l'essentiel

- 1 Une sauvegarde hors-ligne testée agit sur quel facteur du risque : la menace, la vulnérabilité ou l'impact ?
L'impact. Elle ne rend pas l'attaque moins probable, elle la rend moins grave.
- 2 En 2026, quel est le premier vecteur d'accès initial observé dans les violations de données ?
L'exploitation de vulnérabilités (31 %), devant l'abus d'identifiants (13 %).
- 3 Un attaquant peu qualifié loue un rançongiciel et reverse une part de la rançon. Comment s'appelle ce modèle ?
Le Ransomware-as-a-Service ; l'attaquant est un « affilié ».
- 4 Un serveur Web émet toutes les cinq minutes une requête DNS vers un domaine créé hier. Quelle étape de la Kill Chain ?
Étape 6, commande et contrôle. Parade : filtrage du trafic sortant.
- 5 Pourquoi la Kill Chain décrit-elle mal une fraude commise par un salarié ?
Il possède déjà un accès légitime : pas de livraison, d'exploitation ni d'installation à détecter.

Ce qu'il faut retenir de ce module

- 1 On protège la **disponibilité, l'intégrité, la confidentialité** et la **preuve**.
Le risque se réduit en agissant sur la vulnérabilité et l'impact.
- 2 La menace est **industrialisée** : rançongiciel, failles non corrigées, tiers compromis. Les grandes fuites partent d'un **compte légitime volé**.
- 3 Du **script kiddie** à l'**État**, la motivation fixe la cible et la persévérance.
L'**interne** a déjà les clés.
- 4 Surface, **vecteur**, exploit, charge utile : quatre mots distincts. Les familles d'attaques se **combinent**.
- 5 Une attaque est une **chaîne de 7 étapes** : la rompre tôt, n'importe où, suffit. D'où la **défense en profondeur**.

Et ensuite ?

Ces fondations mènent directement aux modules suivants :

Pilotage des risques : ANSSI, ISO 27001, MITRE

DevSecOps et « shift left »

OWASP Top 10:2025

À faire dès lundi

MFA partout, y compris pour les tiers ; correctifs des services exposés ; une sauvegarde hors-ligne **restaurée pour de vrai**.

Sources et références

Chiffres cités

- **ANSSI / CERT-FR** — Panorama de la cybermenace 2025 (mars 2026), cyber.gouv.fr
- **Verizon** — Data Breach Investigations Report 2026
- **IBM, Ponemon Institute** — Cost of a Data Breach Report 2026

Modèles et référentiels

- **Lockheed Martin** — Intelligence-Driven Computer Network Defense (2011)
- **MITRE ATT&CK** — attack.mitre.org
- **Unified Kill Chain** — unifiedkillchain.com
- **OWASP Top 10:2025** — owasp.org/Top10

Ressources en français

- **Guide d'hygiène informatique** de l'ANSSI : 42 mesures
- **EBIOS Risk Manager** : la méthode française d'analyse de risque
- **cybermalveillance.gouv.fr** : assistance et fiches réflexes
- **CERT-FR** : alertes et avis de sécurité, cert.ssi.gouv.fr

Cadre légal

Tester la sécurité d'un système sans l'autorisation écrite de son propriétaire est un délit (articles 323-1 et suivants du Code pénal). Les techniques offensives de cette formation se pratiquent uniquement sur les environnements fournis.

Fin du module 1

Des questions ?

Nous savons désormais **ce que l'on protège, contre qui** et **comment se déroule une attaque**. Place au pilotage et à la maîtrise des risques.